adding a device identifier to the message as *associated data*,[1] which you'll recall from chapter 6 is authenticated but not encrypted, the API can look up the device profile to find the key to decrypt and authenticate messages from that device.

Unfortunately, this is not enough to ensure that API requests really did come from that device, so it is dangerous to make access control decisions based solely on the Message Authentication Code (MAC) used to authenticate the message. The reason is that API requests can be captured by an attacker and later replayed to perform the same action again at a later time, known as a *replay attack*. For example, suppose you are the leader of a clandestine evil organization intent on world domination. A monitoring device in your Uranium enrichment plant sends an API request to increase the speed of a centrifuge. Unfortunately, the request is intercepted by a secret agent, who then replays the request hundreds of times, and the centrifuge spins too quickly causing irreparable damage and delaying your dastardly plans by several years.

> **DEFINITION** In a ***replay attack***, an attacker captures genuine API requests and later replays them to cause actions that weren't intended by the original client. Replay attacks can cause disruption even if the message itself is authenticated.

To prevent replay attacks, the API needs to ensure that a request came from a legitimate client and is *fresh*. Freshness ensures that the message is recent and hasn't been replayed and is critical to security when making access